Comparación de resultados de OWASP ZAP

Aplicación revisada: WebEmpresa · http://localhost:5050 · ZAP 2.17.0

Escaneo inicial: 12 de octubre de 2026, 19:53:51 **Escaneo posterior:** 12 de octubre de 2026, 20:48:19

Comparación de alertas

Alerta	Riesgo	Antes	Después	Comentario
CSP: Directiva Wildcard	Medio	2 instancias	3 instancias	Sigue pendiente. En el segundo escaneo se encontraron más casos.
CSP: Directiva sin mecanismo de reserva	Medio	2 instancias	3 instancias	La política CSP todavía necesita definir una directiva de respaldo.
CSP: script-src unsafe-inline	Medio	2 instancias	3 instancias	ZAP sigue señalando que se permite ejecutar scripts en línea.
CSP: style-src unsafe-inline	Medio	2 instancias	3 instancias	La política todavía permite estilos en línea, por lo que la alerta continúa.
Falta el encabezado X-Content-Type-Options	Bajo	5 respuestas afectadas; alerta sistémica	Alerta sistémica	Se comprobó que una respuesta incluía el valor nosniff, pero ZAP aún muestra la alerta. Hace falta repetir el escaneo y revisar otras respuestas.
Aplicación Web Moderna	Informativo	2 instancias	3 instancias	Es una alerta informativa; por sí sola no significa que exista una vulnerabilidad.
Divulgación de información: comentarios sospechosos	Informativo	1 instancia	1 instancia	ZAP encontró un comentario en JavaScript. Conviene revisar si contiene información que no debería mostrarse.
Respuesta de Gestión de Sesión Identificada	Informativo	2 instancias	5 instancias	ZAP identificó la cookie antiforgery. Esto no significa, por sí solo, que haya una vulnerabilidad.

Resumen

En los dos escaneos no aparecieron alertas de riesgo alto. Se mantuvieron cuatro tipos de alertas de riesgo medio, una de riesgo bajo y tres informativas. En el segundo informe aumentó la cantidad de instancias en varias alertas; esto puede deberse a que ZAP revisó más solicitudes o rutas de la aplicación. Por eso, el aumento no demuestra por sí solo que hayan aparecido nuevas vulnerabilidades, pero sí indica que hay puntos que todavía se deben revisar.

Qué queda por revisar

Las cuatro alertas relacionadas con la política CSP siguen pendientes. También hay que volver a comprobar el encabezado X-Content-Type-Options: aunque una prueba mostró el valor **nosniff**, el escáner todavía lo reporta. Lo mejor es ejecutar otro escaneo y verificar las respuestas que siguen generando la alerta. Por último, conviene revisar el comentario de JavaScript y dejar documentadas las alertas informativas.

Nota: esta comparación se hizo con los resultados disponibles de ambos informes. Los datos deben confirmarse con un nuevo escaneo antes de dar por corregida alguna alerta.